

Nombre: _____ Fecha: _____ Nota: _____

Instrucciones: Lee con atención cada pregunta. Responde de forma clara y concisa en el espacio disponible. La prueba tiene un valor total de **10 puntos** (2 puntos por cada pregunta). Tiempo estimado: 30 minutos.

1. Explica la diferencia entre **riesgo inherente** y **riesgo residual**. Menciona cómo se relaciona cada uno con los controles de seguridad.
2. ¿Qué es el modelo de amenazas **STRIDE** y para qué se utiliza en el ciclo de desarrollo de sistemas? Nombra al menos **cuatro** de sus categorías y describe brevemente qué tipo de amenaza representa cada una.
3. Una empresa aplica el ciclo PHVA para gestionar su plan de seguridad. Durante la fase de *Verificar*, detecta que el 65% de los empleados no ha completado el curso obligatorio de concienciación en seguridad, aunque el resto de los controles técnicos funcionan correctamente.
 - ¿Qué acción concreta debe tomar la empresa en la fase *Actuar* para corregir esta desviación?
 - Proponga un **KPI** que ayude a monitorear el cumplimiento de la capacitación en el futuro.
4. Lee el siguiente caso: *Un banco permite a sus agentes de atención al cliente ver el número completo de la tarjeta de crédito en pantalla para resolver quejas más rápido. Esta práctica viola la normativa PCI DSS, que exige enmascarar los dígitos (mostrar solo los últimos 4). Un agente descontento copia varios números de tarjetas y los vende en foros clandestinos.*
 - Identifique el **fallo en el proceso de negocio** que permitió el incidente.
 - Proponga **dos** controles de seguridad que deberían haberse integrado en dicho proceso para evitar la fuga de datos.
5. Una organización tiene un **apetito de riesgo** Alto, pero su **tolerancia al riesgo** para el tiempo de inactividad es de **máximo 3 horas al año**. El equipo de seguridad propone invertir **\$30,000** en un sistema de alta disponibilidad que reduciría el tiempo de caída de **6 horas/año** a **2 horas/año****. El **ALE actual (sin inversión)** es de ****\$180,000 anuales**.
 - Calcule el **ROSI** de esta inversión (muestre la fórmula y los cálculos).
 - Con base en el resultado y en la tolerancia definida, ¿recomendaría aprobar la inversión? Justifique su respuesta.